



UNIVERSIDAD NACIONAL AUTÓNOMA DE MÉXICO

FACULTAD DE INGENIERÍA

DIPLOMADO EN CIBERSEGURIDAD GEN 18

Módulo 3.3 Análisis Forense

Proyecto

Santiago Alejandro Aldo

Semestre 2026-1

Índice

Objetivo	2
Reporte Ejecutivo	2
Contexto del Incidente	3
Cadena de custodia	4
Reporte Técnico	6
Detalles del caso	6
Metodología del Análisis	6
Acciones del analista iniciales (alteración mínima de evidencia)	6
Perfilamiento del equipo	7
Análisis de medios, artefactos y evidencias	7
Preservación inicial de Metadatos.....	7
Firmas Hash (comandos).....	8
Firmas Hash (archivos).....	9
Identificación del vector de intrusión	10
Persistencia.....	12
Puerto SSH adicional.....	12
Tareas programadas en crontabs	13
Artefacto /usr/bin/cron1.x.....	15
Análisis de malware	16
Perfilamiento del malware	16
Análisis dinámico.....	17
Análisis a nivel red.....	19
Línea del tiempo	20
Cronología del Incidente de Seguridad (23 de noviembre de 2016)	20
Recomendaciones para erradicación	21
Contención	21
Seguridad en cuentas y accesos	21
Hardening de servicios expuestos	21

Objetivo

El alumno tomará el rol de especialista forense que forma parte del equipo de respuesta a incidentes de una reconocida agencia que ofrece servicios de seguridad de la información de manera pública, donde deberá desenvolverse realizando tareas propias de un “First Responder”, y tomará la responsabilidad de dar seguimiento a este incidente. Parte de las acciones a su cargo son la correcta adquisición bajo cadena de custodia, preservación y análisis de toda la evidencia generada en el caso.

El objetivo del presente análisis forense es identificar la causa raíz del compromiso de seguridad en el servidor Linux, determinar el vector de ataque, analizar el mecanismo de persistencia del malware detectado y proponer acciones de remediación para evitar la reincidencia

Reporte Ejecutivo

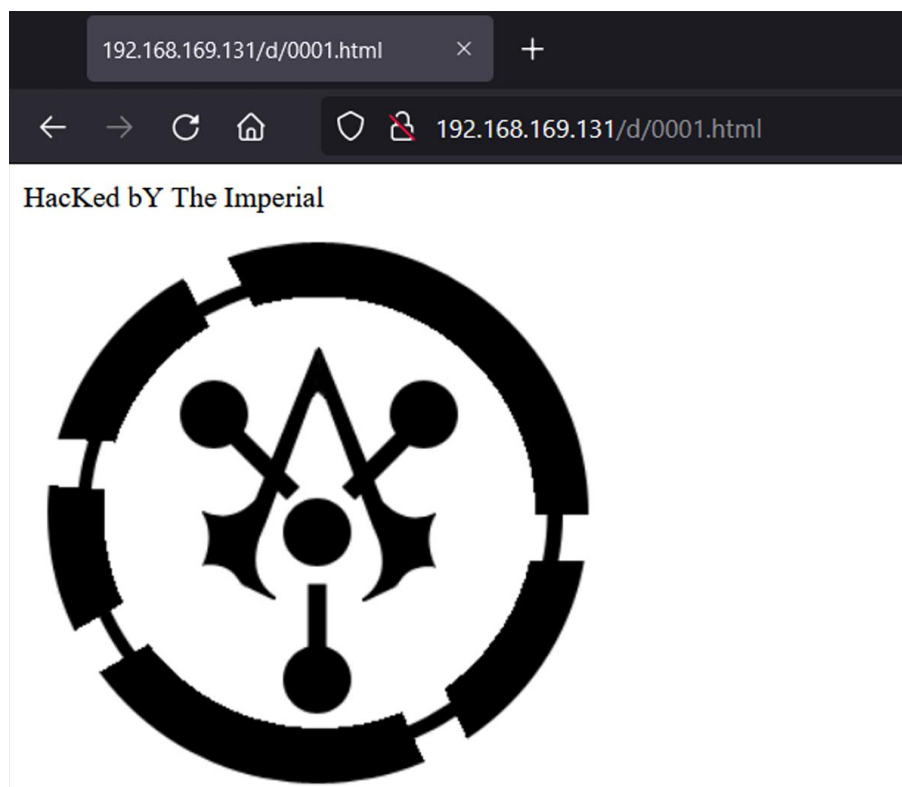
El presente informe detalla el análisis forense realizado tras la detección de una alteración no autorizada en el servidor web de la organización. La investigación identifica el vector de entrada, las medidas de persistencia establecidas por el atacante y el funcionamiento técnico del artefacto malicioso empleado para mantener el compromiso de integridad. El compromiso del sistema inicia mediante un ataque de fuerza bruta exitoso contra el servicio SSH dirigido a la cuenta del superusuario root. Los registros de auditoría confirman que el actor malicioso logra obtener acceso legítimo, procediendo de inmediato a ejecutar tareas de reconocimiento y post-explotación.

Se recomienda la eliminación inmediata del usuario no autorizado (apache), la restauración de las configuraciones originales de SSH, el borrado de las tareas de CRON identificadas y el endurecimiento de las políticas de autenticación mediante el uso de llaves criptográficas y la deshabilitación del acceso directo de root por red.

Contexto del Incidente

Se requiere dar respuesta a un incidente identificado en un servidor donde únicamente los usuarios autorizados pueden publicar contenido en la página disponible. El administrador del sitio web identificó la presencia de una imagen que no corresponde con el contenido de su sitio web público, intentando solucionar la situación el administrador eliminó el archivo contenido en el directorio ***[/var/www/d/0001.html]***, pero después de un minuto aproximadamente el recurso externo reaparece de nueva cuenta, por lo que el administrador del sitio sospecha que su equipo se encuentra comprometido y controlado de manera remota.

En la siguiente imagen se muestra el recurso reportado al equipo de respuesta a incidentes de seguridad:



Cadena de custodia

No. Item	Descripción de la evidencia	Fecha/hora de recolección	Recolectado por:	Firma Hash (SHA256 y MD5)
Archivo comprimido “Ejercicio_LinuxVivo.7z”	Archivo comprimido proporcionado para analizar	15/12/2025 21:44 hrs	Aldo Santiago Alejandro	SHA256: 085ad0076bface7542fde653a47e589d32eb4fe012c01b0876f1adbcafa76c2 MD5: 3c3e5a165dd24e4fa157528ea06842d8
ps_aux.txt	Listado de Procesos Activos (ps aux): Captura del estado actual de todos los procesos en ejecución en el Servidor Afectado ([Ejercicio_LinuxVivo]) al momento de la adquisición en vivo.	16/12/2025 00:33 hrs	Aldo Santiago Alejandro	SHA256: 3aabd4f400f366f5b10d8e8b566aaea6d67106a26dfa393bec86484e980122e9 MD5: dc4c83d2297394f192b9d654d5ab6f17
Archivo “netstat.txt”	Conexiones de Red Activas (netstat -at): Captura del estado de la tabla de conexiones de red TCP, UDP	16/12/2025 00:34 hrs	Aldo Santiago Alejandro	SHA256: c2c7b4dd7edccbcafa097af045f66aeb1f7c83616c63111130f90c94db36602c3 MD5: 5bcba196ff02614b26e782d73b38a547
Archivo “0001.html”	Archivo sospechoso que no corresponder al sitio web original. Copia desde /var/www/d/0001.html.	16/12/2025 00:45 hrs	Aldo Santiago Alejandro	SHA256: c5d6d42d22df8100ee2cf09c326ba0ce9965321f0da85b5554bab520fbf48a2b MD5: 27368358fce1b3648aa09b0b323bb11e
Archivo “auth.log”	Copia de /var/log/auth.log de la máquina víctima. Contiene historial de logs.	16/12/2025 00:47 hrs	Aldo Santiago Alejandro	SHA256: 7f3dd460515a0e351727332d1941c99d0137860c9a3942b4b0059d21ccbd503d MD5: 94e16e53b23b84a36fa0f215904c06a4
Archivo “passwd”	Copia de /etc/passwd de la máquina víctima. Contiene usuarios.	16/12/2025 00:47 hrs	Aldo Santiago Alejandro	SHA256: eb33d1a00aa6a286b1c7063ec72a617525151c239a81257150f09cad2444f56 MD5: db9ef7ca1034b3932d43599d6abba797
Archivo “crontab.txt”	Tareas Programadas (crontab): Listado de los trabajos programados activos para el usuario root y otros usuarios. Obtenido del comando 'ls -l /var/spool/cron/crontabs'.	17/12/2025 00:13 hrs	Aldo Santiago Alejandro	SHA256: 6b3639a71c4fb64be707d6ceea98408f172478d7902decacdfb5ab593e1a1863 MD5: 4c41cb6076419c58031f597d0e069fa9
Archivo “root”	Copia de /var/spool/cron/crontabs/root de la máquina víctima. Contiene las tareas programadas del usuario root.	17/12/2025 00:28 hrs	Aldo Santiago Alejandro	SHA256: 06469361163fc6f62e026fc3874f77dee626ca42580bc8096b5dbc6d7b488bc3 MD5: f515e52e0d18a0e4e8da4a77d85378cd
Archivo “apache”	Copia de /var/spool/cron/crontabs/apache de la máquina víctima. Contiene las tareas programadas del usuario apache	17/12/2025 00:29 hrs	Aldo Santiago Alejandro	SHA256: bb21379e54936f31d505ae340d6ddaeff5ae70c6e72781b2a1217cf8a2317f37 MD5: 675688cf19a3af9a8edbd2a9bd53320

Archivo “cron1.x”	Copia de /usr/bin/cron1.x de la máquina víctima. Malware. Principal artefacto de persistencia.	17/12/2025 01:04 hrs	Aldo Santiago Alejandro	SHA256: 888930686b8e3f121afb1306cb56795cbe233a83f8efd217d53b21213d1b0915 MD5: 6c4f96c2fec4d74bcf27c72f373724fe
Archivo “Strings_cron.txt”	Archivo que contiene los strings del archivo malicioso. Su función es ayudar a analizar el contenido del malware.	17/12/2025 09:41 hrs	Aldo Santiago Alejandro	SHA256: df5b254796ad5cfb994e94e9cdde710d703ca93598e2fdb37d4de8507e472a8 MD5: 8c8c9197f2bf4cecf667080025d46d3f
Archivo “strace.txt”	Archivo que contiene las llamadas a sistema, procesos, ejecuciones y valores de retorno. Ejecutado sin permisos elevados.	17/12/2025 10:14 hrs	Aldo Santiago Alejandro	SHA256: e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855 MD5: d41d8cd98f00b204e9800998ecf8427e
Archivo “sudo_strace.txt”	Archivo que contiene las llamadas a sistema, procesos, ejecuciones y valores de retorno. Ejecutado con permisos elevados.	17/12/2025 16:10 hrs	Aldo Santiago Alejandro	SHA256: 8c9a44de5108b5103caf286985e0bbf6f7c6aba3e63e2b8e607fdbccefbbe8a7 MD5: 2348c092ca9bee2035dbcd87809f132a
Archivo “sshd_config”	Copia de archivo de configuración del servicio ssh.	18/12/2025 01:07 hrs	Aldo Santiago Alejandro	SHA256: 6c1baf74b330fe229a617af94a4522a8415ec499df9bdbf682daaa3dc305c59e MD5: 14eefb6466ffe2cc10d837639b0ac52b

Nota sobre la Integridad: Durante el proceso de recolección de artefactos, se aplicó estrictamente el principio de **alteración mínima de la evidencia**. Para garantizar que el estado del medio de almacenamiento original se mantuviera intacto, se implementaron las siguientes medidas técnicas:

- **Transferencia de Archivos:** La adquisición de archivos estáticos desde la máquina víctima se realizó exclusivamente mediante el protocolo SCP (Secure Copy Protocol) hacia la estación de trabajo del analista (SIFT Workstation).
- **Ejecución de Comandos en Vivo:** Los comandos destinados a obtener el estado del sistema (como ps, netstat o stat) se ejecutaron de forma remota a través de SSH, redireccionando la salida estándar directamente hacia la máquina analista.

Esta estrategia evita cualquier operación de escritura en el disco duro de la víctima, impidiendo la sobreescritura de metadatos o de información sensible alojada en el espacio no asignado del sistema de archivos.

Reporte Técnico

Detalles del caso

Nombre del Caso: Evaluación Final Práctica 18G - Incidente LinuxVivo.

Analista: Aldo Santiago Alejandro.

Fecha de Inicio: 13 de diciembre de 2025.

Metodología del Análisis

Análisis en Vivo: El análisis en vivo fue estrictamente necesario y prioritario debido a la naturaleza del incidente reportado: la **regeneración automática y persistente** de un archivo web malicioso (0001.html) cada 60 segundos. Esta conducta indicaba la presencia de un proceso activo o residente en memoria que, de haber apagado el sistema inmediatamente, se habría perdido irremediablemente. El análisis en vivo permitió:

- La recolección de la tabla de conexiones de red para identificar posibles canales de Comando y Control (C2).
- La identificación de tareas programadas (cron) activas que fungían como mecanismo de persistencia.

Acciones del analista iniciales (alteración mínima de evidencia)

Primera autenticación directamente desde la VM con las credenciales con la finalidad de conocer la IP asignada.

```
V2 login: root
Password:
Last login: Wed Feb 17 12:52:05 CST 2021 on tty1
Linux V2 3.2.0-4-amd64 #1 SMP Debian 3.2.68-1+deb7u6 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@V2:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue state UNKNOWN
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP ql
    en 1000
    link/ether 82:55:c2:00:08:00 brd ff:ff:ff:ff:ff:ff
    inet 192.168.231.145/24 scope global eth0
        inet6 fe80::8255:c200:800:ff/64 scope link
            valid_lft forever preferred_lft forever
root@V2:~# _
```

Imagen 1. Output inmediato después de la primera autenticación del analista

La imagen detalla la fecha en la que se realizó el último inicio de sesión del sistema.

Autenticación root al servidor desde SSH: Desde **192.168.231.139** (IP máquina analista).

```

root@192.168.231.145's password:
Linux V2 3.2.0-4-amd64 #1 SMP Debian 3.2.68-1+deb7u6 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Dec 14 12:44:59 2025
root@V2:~# date
Sun Dec 14 12:51:16 CST 2025
root@V2:~#

```

Imagen 2. Autenticación a root mediante SSH por el analista

Perfilamiento del equipo

Hostname: V2

Sistema Operativo: Debian GNU/Linux

Version: Debian 7

IP: 192.168.231.145

Versión Kernel: 3.2.0-4-amd64

```

root@V2:~# hostname
V2
root@V2:~# uname -a
Linux V2 3.2.0-4-amd64 #1 SMP Debian 3.2.68-1+deb7u6 x86_64 GNU/Linux
root@V2:~#

```

Imagen 3. Comando 'hostname' y 'uname -a'

Análisis de medios, artefactos y evidencias

Con base en el contexto inicial del escenario, se priorizó la identificación de posibles artefactos clave para la construcción de la **Línea de Tiempo** del incidente.

Preservación inicial de Metadatos

Antes de cualquier transferencia, se procedió a la documentación y registro de las marcas de tiempo (MAC Times) de los archivos sospechosos utilizando el comando **stat**. Esta acción es fundamental para la posterior **Generación y Análisis de la Línea de Tiempo**, ya que provee el punto de referencia para las fechas de creación y modificación.

```

root@V2:~# stat /etc/passwd
  File: '/etc/passwd'
  Size: 1063      Blocks: 8          IO Block: 4096   regular file
Device: fe00h/65024d Inode: 22263        Links: 1
Access: (0644/-rw-r--r--)  Uid: (    0/   root)   Gid: (    0/   root)
Access: 2025-12-14 12:44:13.626851004 -0600
Modify: 2016-11-23 10:04:10.855356944 -0600
Change: 2016-11-23 10:04:10.871356109 -0600
 Birth: -

```

Imagen 4. Comando 'stat' a /etc/passwd


```

root@V2:~# stat /var/log/auth.log
  File: '/var/log/auth.log'
  Size: 174281      Blocks: 352      IO Block: 4096   regular file
Device: fe00h/65024d Inode: 47       Links: 1
Access: (0640/-rw-r--r--)  Uid: (   0/   root)   Gid: (   4/   adm)
Access: 2025-12-14 15:22:42.174869967 -0600
Modify: 2025-12-14 16:10:01.490877086 -0600
Change: 2025-12-14 16:10:01.490877086 -0600
 Birth: -

```

Imagen 5. Comando 'stat' a /var/log/auth.log

Se reconoce que las marcas de tiempo de Modificación (M-time) y Acceso (A-time) de este archivo **fueron alteradas inevitablemente** durante la fase de Adquisición en Vivo. Esto se debe a que cada conexión SSH legítima realizada por el analista genera una nueva entrada de *log*, contaminando los metadatos de los archivos.

No obstante, esta modificación en los metadatos **no invalida** el valor del archivo. La **Línea de Tiempo** del incidente no se basa en los *tiempos MAC* del archivo *auth.log* en sí, sino en las **marcas de tiempo internas** registradas dentro del *cuerpo* del *log*. Estas marcas internas son las que se utilizarán para:

1. Determinar el **Vector de Intrusión** a través de patrones de autenticación sospechosos.
2. Establecer el **punto de entrada** y la línea de tiempo del atacante antes de la intervención forense.

```

root@V2:~# stat /var/www/d/0001.html
  File: '/var/www/d/0001.html'
  Size: 113        Blocks: 8         IO Block: 4096   regular file
Device: fe00h/65024d Inode: 129393      Links: 1
Access: (0644/-rw-r--r--)  Uid: (   0/   root)   Gid: (   0/   root)
Access: 2025-12-14 15:21:14.686869505 -0600
Modify: 2016-11-23 10:37:01.947767222 -0600
Change: 2016-11-23 10:37:01.947767222 -0600

```

Imagen 6. Comando 'stat' a /var/www/d/0001.html

Una vez aseguradas las marcas de tiempo, se procedió a la adquisición de los artefactos del sistema de archivos mediante SSH.

Firmas Hash (comandos)

La canalización de los datos a través de SSH garantiza la **integridad de la evidencia en el disco de la víctima** al evitar que se realicen operaciones de **escritura** sobre el medio de almacenamiento. De esta forma, se minimiza la contaminación y el riesgo de sobrescribir evidencia potencialmente valiosa en el espacio no asignado

```
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ ssh root@192.168.231.145 "ps aux" >> psaux.txt
root@192.168.231.145's password:
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ ssh root@192.168.231.145 "netstat -punta" >> netstat.txt
root@192.168.231.145's password:
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ ls
netstat.txt psaux.txt
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ head -2 netstat.txt
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ head -2 psaux.txt
USER          PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root           1  0.0  0.0  10648   828 ?        Ss   12:44   0:00 init [2]
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ sha256sum
sha224sum sha256deep sha256sum
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ sha256sum psaux.txt netstat.txt
3aab4d4f400f366f5b10d8e8b566aaea6d67106a26dfa393bec86484e980122e9 psaux.txt
c2c7b4dd7edccbcacf097af045f66aeb1f7c83616c63111130f90c94db36602c3 netstat.txt
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ md5sum psaux.txt netstat.txt
dc4c83d2297394f192b9d654d5ab6f17 psaux.txt
5bcba196ff02614b26e782d73b38a547 netstat.txt
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
```

Imagen 7. Redireccionamiento de output de comandos a la máquina analista y posteriormente, generación de firmas hash.

Firmas Hash psaux.txt

SHA256:

3aab4d4f400f366f5b10d8e8b566aaea6d67106a26dfa393bec86484e980122e9

MD5: dc4c83d2297394f192b9d654d5ab6f17

Firmas Hash netstat.txt

SHA256:

c2c7b4dd7edccbcacf097af045f66aeb1f7c83616c63111130f90c94db36602c3

MD5: 5bcba196ff02614b26e782d73b38a547

Firmas Hash (archivos)

Además de los comandos que muestran actividad en la red y procesos, hacemos una copia a los archivos con posibles evidencias de ataque.

```
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ scp root@192.168.231.145:/var/www/d/0001.html .
root@192.168.231.145's password:
0001.html 100% 113 45.1KB/s 00:00
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ scp root@192.168.231.145:/var/log/auth.log .
root@192.168.231.145's password:
auth.log 100% 152KB 16.0MB/s 00:00
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ scp root@192.168.231.145:/etc/passwd .
root@192.168.231.145's password:
passwd 100% 1063 1.5MB/s 00:00
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ sha256sum 0001.html auth.log passwd
c5d6d42d22df810ee2cf09c326ba0ce9965321f0da85b5554ab520fbf48a2b 0001.html
7f3dd460515a0e351727332d1941c99d0137860c9a3942b4b0059d21ccbd503d auth.log
eb33d1a00aa6a286b1c7063ec72a617525151c239a81257150f09cad2444f56 passwd
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ md5sum 0001.html auth.log passwd
27368358fce1b3648aa09b0b323bb1e 0001.html
94e16e53b23b84a36fa0f215904c06a4 auth.log
db9ef7ca1034b3932d43599d6abba797 passwd
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
```

Imagen 8. Canalización de artefactos a la máquina analista y posteriormente, generación de firmas hash.

Firmas Hash 0001.html

SHA256:

c5d6d42d22df8100ee2cf09c326ba0ce9965321f0da85b5554bab520fbf48a2b

MD5: 27368358fce1b3648aa09b0b323bb11e

Firmas Hash auth.log

SHA256:

7f3dd460515a0e351727332d1941c99d0137860c9a3942b4b0059d21ccbd503d

MD5: 94e16e53b23b84a36fa0f215904c06a4

Firmas Hash /etc/passwd

SHA256:

eb33d1a00aa6a286b1c7063ec72a617525151c239a81257150f09cadc2444f56

MD5: db9ef7ca1034b3932d43599d6abba797

Identificación del vector de intrusión

Se procedió al análisis del contenido del archivo auth.log adquirido, utilizando el comando grep para filtrar entradas relacionadas con el servicio SSH (sshd) y la autenticación fallida (Failed password). El análisis reveló un patrón de actividad sospechosa consistente con un ataque de **Fuerza Bruta** o **Diccionario** dirigido a obtener acceso SSH. El actor malicioso intentó autenticarse sistemáticamente utilizando usuarios predecibles o comunes, incluyendo: admin, administrador y root.

```
Nov 23 09:26:04 V2 sshd[3142]: Failed password for invalid user admin from 192.168.127.148 port 41921 ssh2
Nov 23 09:26:04 V2 sshd[3141]: Failed password for invalid user admin from 192.168.127.148 port 41920 ssh2
Nov 23 09:26:04 V2 sshd[3140]: Failed password for invalid user admin from 192.168.127.148 port 41919 ssh2
Nov 23 09:26:04 V2 sshd[3143]: Failed password for invalid user admin from 192.168.127.148 port 41922 ssh2
Nov 23 09:26:06 V2 sshd[3141]: Failed password for invalid user admin from 192.168.127.148 port 41920 ssh2
Nov 23 09:26:06 V2 sshd[3143]: Failed password for invalid user admin from 192.168.127.148 port 41922 ssh2
Nov 23 09:26:06 V2 sshd[3140]: Failed password for invalid user admin from 192.168.127.148 port 41919 ssh2
Nov 23 09:26:06 V2 sshd[3142]: Failed password for invalid user admin from 192.168.127.148 port 41921 ssh2
Nov 23 09:26:08 V2 sshd[3140]: Failed password for invalid user admin from 192.168.127.148 port 41919 ssh2
Nov 23 09:26:08 V2 sshd[3142]: Failed password for invalid user admin from 192.168.127.148 port 41921 ssh2
Nov 23 09:26:08 V2 sshd[3141]: Failed password for invalid user admin from 192.168.127.148 port 41920 ssh2
Nov 23 09:26:08 V2 sshd[3143]: Failed password for invalid user admin from 192.168.127.148 port 41922 ssh2
Nov 23 09:26:09 V2 sshd[3140]: Failed password for invalid user admin from 192.168.127.148 port 41919 ssh2
Nov 23 09:26:09 V2 sshd[3143]: Failed password for invalid user admin from 192.168.127.148 port 41922 ssh2
Nov 23 09:26:10 V2 sshd[3148]: Failed password for invalid user administrator from 192.168.127.148 port 41923 ssh2
Nov 23 09:26:10 V2 sshd[3149]: Failed password for invalid user administrator from 192.168.127.148 port 41924 ssh2
Nov 23 09:26:11 V2 sshd[3148]: Failed password for invalid user administrator from 192.168.127.148 port 41923 ssh2
Nov 23 09:26:11 V2 sshd[3149]: Failed password for invalid user administrator from 192.168.127.148 port 41924 ssh2
Nov 23 09:26:11 V2 sshd[3154]: Failed password for invalid user administrator from 192.168.127.148 port 41926 ssh2
Nov 23 09:26:11 V2 sshd[3153]: Failed password for invalid user administrator from 192.168.127.148 port 41925 ssh2
Nov 23 09:26:13 V2 sshd[3148]: Failed password for invalid user administrator from 192.168.127.148 port 41923 ssh2
Nov 23 09:26:13 V2 sshd[3149]: Failed password for invalid user administrator from 192.168.127.148 port 41924 ssh2
Nov 23 09:26:13 V2 sshd[3154]: Failed password for invalid user administrator from 192.168.127.148 port 41926 ssh2
Nov 23 09:26:13 V2 sshd[3153]: Failed password for invalid user administrator from 192.168.127.148 port 41925 ssh2
Nov 23 09:26:15 V2 sshd[3149]: Failed password for invalid user administrator from 192.168.127.148 port 41924 ssh2
Nov 23 09:26:15 V2 sshd[3148]: Failed password for invalid user administrator from 192.168.127.148 port 41923 ssh2
Nov 23 09:26:15 V2 sshd[3153]: Failed password for invalid user administrator from 192.168.127.148 port 41925 ssh2
Nov 23 09:26:15 V2 sshd[3154]: Failed password for invalid user administrator from 192.168.127.148 port 41926 ssh2
Nov 23 09:26:17 V2 sshd[3162]: Failed password for invalid user administrador from 192.168.127.148 port 41930 ssh2
Nov 23 09:26:17 V2 sshd[3157]: Failed password for invalid user administrador from 192.168.127.148 port 41927 ssh2
Nov 23 09:26:17 V2 sshd[3158]: Failed password for invalid user administrador from 192.168.127.148 port 41928 ssh2
Nov 23 09:26:17 V2 sshd[3161]: Failed password for invalid user administrador from 192.168.127.148 port 41929 ssh2
Nov 23 09:26:19 V2 sshd[3162]: Failed password for invalid user administrador from 192.168.127.148 port 41930 ssh2
Nov 23 09:26:19 V2 sshd[3158]: Failed password for invalid user administrador from 192.168.127.148 port 41928 ssh2
Nov 23 09:26:19 V2 sshd[3157]: Failed password for invalid user administrador from 192.168.127.148 port 41927 ssh2
```

Imagen 9. Fallos de autenticación desde SSH. Usuarios inválidos. Contenido de auth.log

El ataque culminó en un **acceso exitoso** que comprometió el servidor. A las **09:26:27**, el atacante logró autenticarse satisfactoriamente por SSH, obteniendo acceso al sistema con los privilegios del usuario **root**.

```
Nov 23 09:26:21 V2 sshd[3161]: Failed password for invalid user administrador from 192.168.127.148 port 41929 ssh2
Nov 23 09:26:22 V2 sshd[3162]: Failed password for invalid user administrador from 192.168.127.148 port 41930 ssh2
Nov 23 09:26:23 V2 sshd[3165]: Failed password for root from 192.168.127.148 port 41931 ssh2
Nov 23 09:26:23 V2 sshd[3166]: Failed password for root from 192.168.127.148 port 41932 ssh2
Nov 23 09:26:25 V2 sshd[3171]: Failed password for root from 192.168.127.148 port 41934 ssh2
Nov 23 09:26:25 V2 sshd[3170]: Failed password for root from 192.168.127.148 port 41933 ssh2
Nov 23 09:26:25 V2 sshd[3166]: Failed password for root from 192.168.127.148 port 41932 ssh2
Nov 23 09:26:25 V2 sshd[3165]: Failed password for root from 192.168.127.148 port 41931 ssh2
Nov 23 09:26:27 V2 sshd[3170]: Failed password for root from 192.168.127.148 port 41933 ssh2
Nov 23 09:26:27 V2 sshd[3171]: Failed password for root from 192.168.127.148 port 41934 ssh2
Nov 23 09:26:27 V2 sshd[3166]: Failed password for root from 192.168.127.148 port 41932 ssh2
Nov 23 09:26:27 V2 sshd[3165]: Accepted password for root from 192.168.127.148 port 41931 ssh2
Nov 23 09:26:28 V2 sshd[3171]: Failed password for root from 192.168.127.148 port 41934 ssh2
Nov 23 09:26:28 V2 sshd[3170]: Failed password for root from 192.168.127.148 port 41933 ssh2
Nov 23 09:26:28 V2 sshd[3166]: Failed password for root from 192.168.127.148 port 41932 ssh2
Nov 23 10:01:56 V2 sshd[3233]: Accepted password for root from 192.168.127.148 port 41953 ssh2
```

Imagen 10. Intentos fallidos hasta autenticación exitosa.

Este evento a las 09:26:27 marca el **Vector de Intrusión** inicial, proporcionando al atacante con la IP: 192.168.127.148, el control total del servidor y la capacidad de ejecutar comandos para instalar mecanismos de persistencia.

Una vez confirmado el acceso inicial como usuario root, el análisis del auth.log continuó mediante el filtrado con palabras clave específicas (useradd, CRON, apache) para rastrear las acciones inmediatas del atacante. El examen reveló que, minutos después del login exitoso, el actor malicioso ejecutó comandos para establecer su mecanismo de persistencia.

La siguiente imagen evidencia la creación anómala de un nuevo usuario con la shell activa llamado apache (UID=1001) a las **10:01:57**. Este evento fue seguido por la activación del daemon CRON a nombre del mismo usuario a partir de las **10:14:02**, momento en que comienza el patrón de ejecución repetitiva (cada minuto) que regeneraba el contenido malicioso.

```
$ grep apache auth.log
Nov 23 10:01:57 V2 groupadd[3236]: group added to /etc/group: name=apache, GID=1001
Nov 23 10:01:57 V2 groupadd[3236]: group added to /etc/gshadow: name=apache
Nov 23 10:01:57 V2 groupadd[3236]: new group: name=apache, GID=1001
Nov 23 10:01:57 V2 useradd[3240]: new user: name=apache, UID=1001, GID=1001, home=/home/ap
Nov 23 10:02:15 V2 passwd[3247]: pam_unix(passwd:chauthtok): password changed for apache
Nov 23 10:14:01 V2 CRON[3452]: pam_unix(cron:session): session opened for user apache by (
Nov 23 10:14:02 V2 CRON[3452]: pam_unix(cron:session): session closed for user apache
Nov 23 10:15:01 V2 CRON[3468]: pam_unix(cron:session): session opened for user apache by (
Nov 23 10:15:01 V2 CRON[3468]: pam_unix(cron:session): session closed for user apache
Nov 23 10:16:01 V2 CRON[3493]: pam_unix(cron:session): session opened for user apache by (
Nov 23 10:16:02 V2 CRON[3493]: pam_unix(cron:session): session closed for user apache
Nov 23 10:17:01 V2 CRON[3513]: pam_unix(cron:session): session opened for user apache by (
Nov 23 10:17:01 V2 CRON[3513]: pam_unix(cron:session): session closed for user apache
Nov 23 10:18:01 V2 CRON[3531]: pam_unix(cron:session): session opened for user apache by (
Nov 23 10:18:01 V2 CRON[3531]: pam_unix(cron:session): session closed for user apache
Nov 23 10:19:01 V2 CRON[3554]: pam_unix(cron:session): session opened for user apache by (
Nov 23 10:19:01 V2 CRON[3554]: pam_unix(cron:session): session closed for user apache
Nov 23 10:24:02 V2 CRON[3143]: pam_unix(cron:session): session opened for user apache by (
```

Imagen 11. Usuario 'apache' y contraseña creada. Tarea programada creada e invocada cada minuto.

Los *logs* de autenticación confirman que el atacante obtuvo acceso privilegiado (root), lo que le permitió comprometer el sistema mediante la inyección de un nuevo usuario (apache) y el *setup* inmediato del *job* de cron que garantiza la persistencia del *defacement*.

Este hallazgo establece un vínculo directo entre el usuario apache y el componente de persistencia. Por lo tanto, el siguiente paso de la investigación forense se centrará en analizar el archivo de configuración del sistema de usuarios (/etc/passwd) para obtener más detalles sobre el usuario apache y determinar si se trata de un backdoor o una cuenta de servicio comprometida.

```
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ cat passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
apache:x:0:0:,,,:/home/apache:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuid:x:100:101:/:/var/lib/libuid:/bin/sh
Debian-exim:x:101:103:/:/var/spool/exim4:/bin/false
statd:x:102:65534:/:/var/lib/nfs:/bin/false
ususrartov2:x:1000:1000:ususrartov2:,:/home/ususrartov2:/bin/bash
mysql:x:103:106:MySQL Server:,:/nonexistent:/bin/false
sshd:x:104:65534:/:/var/run/ssh:/usr/sbin/nologin
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
```

Imagen 12. Confirmación de usuario malicioso 'apache' en passwd

Persistencia

Puerto SSH adicional

```
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      2649/mysqld
tcp        0      0 0.0.0.0:57389           0.0.0.0:*               LISTEN      1749/rpc.statd
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      1718/rpcbind
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      2718/sshd
tcp        0      0 0.0.0.0:8822            0.0.0.0:*               LISTEN      2718/sshd
tcp        0      0 127.0.0.1:25            0.0.0.0:*               LISTEN      3129/exim4
tcp        0      0 192.168.231.145:22      192.168.231.139:53808  ESTABLISHED 3303/0
tcp        0      0 192.168.231.145:22      192.168.231.139:47272  ESTABLISHED 5845/sshd: root@not
tcp6       0      0 :::111                  :::*                   LISTEN      1718/rpcbind
tcp6       0      0 :::80                   :::*                   LISTEN      2112/apache2
tcp6       0      0 :::22                   :::*                   LISTEN      2718/sshd
tcp6       0      0 :::8822                 :::*                   LISTEN      2718/sshd
tcp6       0      0 :::125                   :::*                   LISTEN      3129/exim4
tcp6       0      0 :::36092                :::*                   LISTEN      1749/rpc.statd
udp        0      0 0.0.0.0:3587            0.0.0.0:*               *
udp        0      0 0.0.0.0:68              0.0.0.0:*               *
udp        0      0 0.0.0.0:621             0.0.0.0:*               *
udp        0      0 0.0.0.0:111             0.0.0.0:*               *
udp        0      0 127.0.0.1:653           0.0.0.0:*               *
udp        0      0 0.0.0.0:39130           0.0.0.0:*               *
udp6       0      0 :::621                  :::*                   *
udp6       0      0 :::111                  :::*                   *
udp6       0      0 :::40148                 :::*                   *
udp6       0      0 :::33111                 :::*                   *
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 localhost:mysql         *:*                    LISTEN
tcp        0      0 *:57389                 *:*                    LISTEN
tcp        0      0 *:sunrpc                 *:*                    LISTEN
tcp        0      0 *:ssh                    *:*                    LISTEN
tcp        0      0 *:8822                   *:*                    LISTEN
tcp        0      0 localhost:smtp          *:*                    LISTEN
tcp        0      0 192.168.231.145:ssh     192.168.231.139:41234  ESTABLISHED
tcp        0      0 192.168.231.145:ssh     192.168.231.139:40068  ESTABLISHED
```

Imagen 13. Puerto SSH:8822 en escucha sospechoso.

Nota: Las conexiones establecidas desde la IP 192.168.231.139 son del analista.

La inferencia más probable de este puerto abierto adicional en el servicio de SSH es la función de un backdoor. Si el administrador cierra el puerto 22 o bloquea la IP del atacante en ese puerto, el atacante aún puede entrar por el puerto alternativo que el administrador podría haber pasado por alto.

Tras identificar conexiones en puertos no estándar mediante netstat, se procedió a inspeccionar el archivo de configuración del demonio SSH (*/etc/ssh/sshd_config*). Los hallazgos confirman una manipulación deliberada del servicio:

```
root@V2:~# stat /etc/ssh/sshd_config
  File: '/etc/ssh/sshd_config'
  Size: 2504      Blocks: 8        IO Block: 4096   regular file
Device: fe00h/65024d Inode: 21202      Links: 1
Access: (0644/-rw-r--r--)  Uid: (   0/   root)   Gid: (   0/   root)
Access: 2025-12-14 12:44:14.510851004 -0600
Modify: 2016-11-23 10:06:22.175356591 -0600
Change: 2016-11-23 10:06:22.191357201 -0600
 Birth: -
root@V2:~#
```

Imagen 14. Marcas MAC correspondientes a la fecha de ataque

```
# GSSAPI options
#GSSAPIAuthentication no
#GSSAPICleanupCredentials yes

X11Forwarding yes
X11DisplayOffset 10
PrintMotd no
PrintLastLog yes
TCPKeepAlive yes
#UseLogin no

#MaxStartups 10:30:60
#Banner /etc/issue.net

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

Subsystem sftp /usr/lib/openssh/sftp-server

# Set this to 'yes' to enable PAM authentication, account processing,
# and session processing. If this is enabled, PAM authentication will
# be allowed through the ChallengeResponseAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via ChallengeResponseAuthentication may bypass
# the setting of "PermitRootLogin without-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and ChallengeResponseAuthentication to 'no'.
UsePAM yes

Port 8822
sansforensics@st workstation: ~/Desktop/Proyecto/archivos_hash
```

Imagen 15. Puerto 8822 agregado en el archivo de configuración.

Tareas programadas en crontabs

Dando seguimiento a la actividad detectada en los registros de autenticación sobre la creación del usuario apache y la ejecución de tareas programadas, se procedió a realizar un análisis de metadatos mediante el comando stat sobre los archivos de configuración de cron de los usuarios involucrados. Las fechas y horas coinciden con el rango de tiempo en el que se hicieron ataques maliciosos.

```

root@V2:~# stat /var/spool/cron/crontabs/
  File: '/var/spool/cron/crontabs/'
  Size: 4096      Blocks: 8      IO Block: 4096   directory
Device: fe00h/65024d  Inode: 5817      Links: 2
Access: (1730/drwx-wx--T)  Uid: (  0/      root)   Gid: ( 102/ crontab)
Access: 2025-12-14 12:44:14.578851006 -0600
Modify: 2016-11-23 10:13:33.355363511 -0600
Change: 2016-11-23 10:13:33.355363511 -0600
 Birth: -

```

Imagen 16. Comando 'stat' a crontabs.txt

```

root@V2:~# stat /var/spool/cron/crontabs/apache
  File: '/var/spool/cron/crontabs/apache'
  Size: 1116      Blocks: 8      IO Block: 4096   regular file
Device: fe00h/65024d  Inode: 31327     Links: 1
Access: (0600/-rw-----)  Uid: (  0/      root)   Gid: ( 102/ crontab)
Access: 2025-12-14 12:44:14.578851006 -0600
Modify: 2016-11-23 10:13:33.319363923 -0600
Change: 2016-11-23 10:13:33.355363511 -0600
 Birth: -

root@V2:~# stat /var/spool/cron/crontabs/root
  File: '/var/spool/cron/crontabs/root'
  Size: 1116      Blocks: 8      IO Block: 4096   regular file
Device: fe00h/65024d  Inode: 31326     Links: 1
Access: (0600/-rw-----)  Uid: (  0/      root)   Gid: ( 102/ crontab)
Access: 2025-12-14 12:44:14.578851006 -0600
Modify: 2016-11-23 10:12:53.423362476 -0600
Change: 2016-11-23 10:12:53.479362947 -0600
 Birth: -
root@V2:~#

```

Imagen 17. Comando 'stat' a crontabs de usuarios 'apache' y 'root'

De manera simultánea, el archivo de tareas programadas del usuario root muestra una modificación a las 10:12:53 hrs. Esta actividad sugiere que el atacante, aprovechando sus privilegios de superusuario obtenidos previamente (09:26:27 hrs), manipuló tanto su propio crontab como el del usuario recién creado para asegurar múltiples vectores de persistencia. Esto se confirma al revisar la tarea programa de ambos usuarios, que resultan llamar al mismo archivo (*/usr/bin/cron1.x*), que, a su vez, es el siguiente artefacto para analizar.

```

sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ cat root
# DO NOT EDIT THIS FILE - edit the master and reinstall.
# (/tmp/crontab.BNOFRN/crontab installed on Wed Nov 23 10:12:53 2016)
# (Cron version -- $Id: crontab.c,v 2.13 1994/01/17 03:20:37 vixie Exp $)
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
* * * * * /usr/bin/cron1.x

```

Imagen 18. Crontab de root

```
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash
$ cat apache
# DO NOT EDIT THIS FILE - edit the master and reinstall.
# (/tmp/crontab.dal2xu/crontab installed on Wed Nov 23 10:13:33 2016)
# (Cron version -- $Id: crontab.c,v 2.13 1994/01/17 03:20:37 vixie Exp $)
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
* * * * * /usr/bin/cron1.x
```

Imagen 19. Crontab de apache

Firmas Hash contrabs.txt

SHA256:

6b3639a71c4fb64be707d6ceea98408f172478d7902decacdfb5ab593e1a1863

MD5: 4c41cb6076419c58031f597d0e069fa9

Artefacto /usr/bin/cron1.x

Antes de cualquier análisis, copia o modificación, se obtiene sus marcas MAC que coinciden con la fecha y el rango de horas del ataque.

```
root@V2:~# stat /usr/bin/cron1.x
  File: '/usr/bin/cron1.x'
  Size: 835976      Blocks: 1640      IO Block: 4096   regular file
Device: fe00h/65024d Inode: 21228      Links: 1
Access: (0755/-rwxr-xr-x)  Uid: (  0/   root)   Gid: (  0/   root)
Access: 2025-12-14 12:45:01.598851097 -0600
Modify: 2016-11-23 10:16:13.135365741 -0600
Change: 2016-11-23 10:16:13.135365741 -0600
 Birth: -
```

Imagen 20. Comando 'stat' sobre /usr/bin/cron1.txt

El archivo **/usr/bin/cron1.x** ha sido identificado como el artefacto principal de ejecución del incidente. Su ubicación en **/usr/bin/** es una técnica común de evasión para intentar mezclarse con utilidades legítimas del sistema. Dada su relación directa con la persistencia, este archivo se marca como prioridad para su extracción, generación de firma hash y posterior análisis de ingeniería inversa o análisis dinámico en un entorno controlado.

Firmas hash de cron1.x

SHA256:

888930686b8e3f121afb1306cb56795cbe233a83f8efd217d53b21213d1b0915

MD5: 6c4f96c2fec4d74bcf27c72f373724fe

Análisis de malware

Perfilamiento del malware

Se trata de un binario **ELF (Executable and Linkable Format)** de **64 bits** para sistemas GNU/Linux. Además, el binario no ha sido "limpiado" (**not stripped**) de sus símbolos de depuración. Esto facilita enormemente la tarea forense, ya que conserva nombres de funciones y variables originales que pueden ser analizados mediante ingeniería inversa para entender su comportamiento exacto.

```
sansforensics@siftworkstation: ~/Desktop/Proyecto/archivos_hash practical
$ file cron1.x
cron1.x: ELF 64-bit LSB executable, x86-64, version 1 (GNU/Linux), statically linked, for GNU/Linux 2.6.32, BuildID[sha1]=a77c6f7cd8b4d5747fa05519ed9e47c9fe106ef2, not stripped
```

Imagen 21. Comando 'file' a malware. Se trata de un ejecutable de Linux

Además, está escrito en Lenguaje C y compilado con GCC de Debian 4.9.2.

```
▼ ELF64
  Operation system: Debian Linux(ABI: 2.6.32)[AMD64, 64-bit, EXEC] S ?
  Compiler: GCC((Debian 4.9.2-10) 4.9.2) S ?
  Language: C S ?
```

Imagen 22. Perfilamiento según Detect It Easy 3.10

Durante la fase inicial de examen del binario cron1.x, se emplearon diversas metodologías de análisis estático, incluyendo herramientas de extracción de cadenas de texto (*strings*) y software de ingeniería inversa como **Ghidra**. Los resultados de esta fase se resumen a continuación:

- **Resultados de Extracción de Cadenas:** El uso de utilidades para la obtención de *strings* no reveló indicadores de compromiso (IoC) legibles ni rutas críticas relacionadas con el servidor web.
- **Indicios de Ofuscación:** La ausencia de cadenas de texto explícitas, a pesar de que el binario conserva sus símbolos de depuración (*not stripped*), sugiere la implementación de técnicas de **ofuscación de código** o la construcción dinámica de rutas en tiempo de ejecución.
- **Análisis en Memoria de Solo Lectura:** Se identificó que las constantes críticas se encuentran almacenadas de forma opaca dentro de la sección **.rodata**, lo que impide su detección mediante herramientas de búsqueda convencionales sin una interpretación profunda de los punteros de memoria.

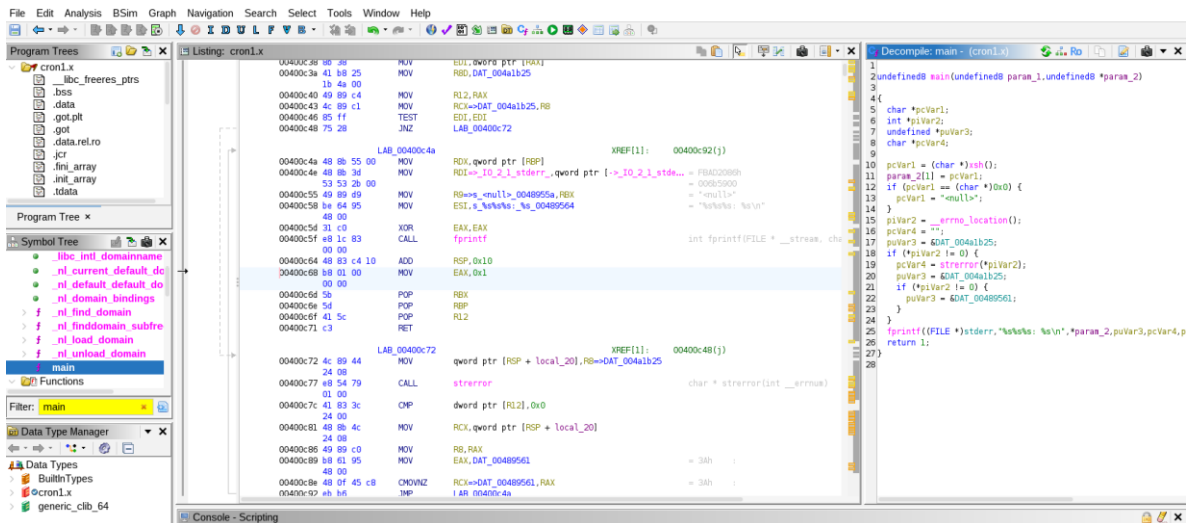


Imagen 23. Uso de Ghidra para decompilar el archivo malicioso

Análisis dinámico

Esta resistencia al análisis estático confirmó la necesidad de transicionar hacia un análisis dinámico, el cual fue el único método capaz de forzar al binario a revelar su interacción con el archivo **0001.html**.

Después de un extenso análisis, se presentan hallazgos importantes al hacer uso del comando 'strace' que nos ayuda a rastrear las llamadas al sistema y señales recibidas a algún proceso, mostrando argumentos y valores de retorno para depurar problemas. En este caso se uso sin permisos elevados, lo que limitó algunas acciones del archivo malicioso, sin embargo, confirmamos la persistencia del archivo **'0001.html'** a través de **'cron1.x'**.

```
sansforensics@siftworkstation: ~/Desktop/Proyecto/malware
$ strace -e trace=open,creat,write ./cron1.x
--- SIGCHLD {si_signo=SIGCHLD, si_code=CLD_EXITED, si_pid=12232, si_uid=1000, si_status=0, si_utime=0, si_stime=0} ---
--- SIGCHLD {si_signo=SIGCHLD, si_code=CLD_EXITED, si_pid=12236, si_uid=1000, si_status=1, si_utime=0, si_stime=0} ---
write(2, "./cron1.x: line 7: /var/www/html/...", 72./cron1.x: line 7: /var/www/html/d/0001.html: No such file or directory
) = 72
write(2, "./cron1.x: line 8: /var/www/html/...", 72./cron1.x: line 8: /var/www/html/d/0001.html: No such file or directory
) = 72
+++ exited with 1 +++
```

Imagen 24. Uso de 'strace' sin permisos elevados

Nota: Este análisis se hizo en un entorno controlado sin salida a Internet y con modificaciones de la configuración de la máquina virtual para mayor seguridad.

De este archivo (**`sudo_strace.txt`**), se confirma que el binario utiliza el intérprete de comandos del sistema (`/bin/bash`) para orquestar sus acciones, lo que le permite usar comandos nativos de Linux fácilmente en lugar de programar toda la lógica en C. El binario se invoca a sí mismo a través de una shell de bash y además, se observa la ejecución del comando para crear el directorio '`d`' dentro de '`/var/www/html`' (pid 18480).

```

sansforensics@stfworkstation: ~/Desktop/Proyecto/malware
$ grep "execve" --line-number sudo_strace.txt
1: execve("/cron1.x", ["/cron1.x"], 0x7ffde6a6e8198 /* 17 vars */) = 0
11: execve("/bin/bash", ["/cron1.x"], 0x7ffde6a6e8198 /* 17 vars */) = 0
100: execve("/home/sansforensics/Desktop/Proyecto/malware/cron1.x", ["/cron1.x"], 0x5612880a4bd0 /* 20 vars */) = 0
110: execve("/bin/bash", ["/cron1.x", "-c", "...", "/cron1.x"], 0x7ffe1162caa8 /* 19 vars */) = 0
DNS_PROBE_FINISHED_NO_INTERNET

461: [pid 18479] execve("/usr/bin/cut", ["cut", "-d", "-f2"], 0x559b48f0caf0 /* 20 vars */ <unfinished ...>
485: [pid 18477] execve("/usr/bin/grep", ["grep", "-r", "DocumentRoot", "/etc/apache2/sites-enabled/000-default.conf"], 0x559b48f0caf0 /* 20 vars */) = 0
524: [pid 18479] <... execve resumed> = 0
567: [pid 18478] execve("/usr/bin/head", ["head", "-1"], 0x559b48f0caf0 /* 20 vars */ <unfinished ...>
569: [pid 18478] <... execve resumed> = 0
944: [pid 18480] execve("/usr/bin/mkdir", ["mkdir", "/var/www/html/d"], 0x559b48f0caf0 /* 20 vars */) = 0

```

Imagen 25. Búsqueda del comando 'execve' con grep dentro del archivo sudo_strace.txt

En la siguiente imagen se muestra la línea en donde se abre el archivo '0001.html' para sobrescribirlo.

```

ransfor@kali:~/workstation: ~/Desktop/Projecto/malware
$ grep www/h sudo strace.txt
[pid 18477] <... read resumed>"VirtualHost *:80\n#\t The ServerName directive sets the request scheme, hostname and port that\n#\t the server
uses to identify itself. This is used when creating\n#\t redirection URLs. In the context of virtual hosts, the ServerName\n#\t specifies what
hostname must appear in the request's Host: header to\n#\t match this virtual host. For the default virtual host (this file) this\n#\t value i
s not decisive as it is used as a last resort host regardless.\n#\t However, you must set it for any further virtual host explicitly.\n#\tServer
Name www.example.com\n#\tServerAdmin webmaster@localhost\n#\tDocumentRoot /var/www/html\n#\t Available loglevels: trace8, ..., trace1, debug
, info, notice, warn,\n#\t error, crit, alert, emerg.\n#\t It is also possible to configure the loglevel for particular\n#\t modules, e.g.\n#\t LogLevel info ssl:warn\n#\tErrorLog $[APACHE_LOG_DIR]/error.log\n#\tCustomLog $[APACHE_LOG_DIR]/access.log combined\n#\t For most configurati
on files from conf-available, which are\n#\t enabled or disabled at a g"... , 98304) = 1332
[pid 18477] write(1, "\tDocumentRoot /var/www/html\n", 28 <unfinished ...>
[pid 18478] read(0, "\tDocumentRoot /var/www/html\n", 8192) = 28
[pid 18478] write(1, "\tDocumentRoot /var/www/html\n", 28) = 28
[pid 18479] <... read resumed>"\tDocumentRoot /var/www/html\n", 4096) = 28
[pid 18479] write(1, "/var/www/html\n", 14 <unfinished ...>
[pid 18475] <... read resumed>"var/www/html\n", 512) = 14
[pid 18480] execve("/usr/bin/mkdir", ["mkdir", "/var/www/html/d"], 0x559b48f0caf0 /* 20 vars */) = 0
[pid 18480] mkdir("/var/www/html/d", 0777) = 0
newstatat(AT_FDCWD, "/var/www/html/d/0001.html", 0x7ffdf908b3f0, 0) = -1 ENOENT (No such file or directory)
openat(AT_FDCWD, "/var/www/html/d/0001.html", O_WRONLY|O_CREAT|O_TRUNC, 0666) = 3
openat(AT_FDCWD, "/var/www/html/d/0001.html", O_WRONLY|O_CREAT|O_APPEND, 0666) = 3

```

Imagen 26. Búsqueda de la cadena '/var/w' sobre el archivo sudo strace.txt

Aunado a la imagen anterior, lo que se sobrescribiría al archivo html serían las cadenas seleccionadas en la siguiente imagen:

```
[pid 18480] mmap(0x7f6532657000, 103808, PROT_READ|MAP_PRIVATE|MAP_FIXED|MAP_DENYWRITE, 3, 0x000000) = 0x7f6532657000
[pid 18480] mmap(0x7f6532657000, 8192, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_FIXED|MAP_DENYWRITE, 3, 0x940000) = 0x7f6532657000
[pid 18480] mmap(NULL, 12288, PROT_READ|PROT_WRITE, MAP_PRIVATE|MAP_ANONYMOUS, -1, 0) = 0x7f65325bf000
write(1, "HaCkEd BY The Imperial <br>\n", 28) = 28
write(1, "<img src='http://vignette4.wikia.nocookie.net/swfanon/images/2/27/CruentusLogo.png'>\n", 85) = 85
sansforensics@siftworkstation: ~/Desktop/Proyecto/malware
```

Imagen 27. Inserción del contenido de '0001.html'

Con la ejecución con privilegios elevados (sudo) se revela que '**cron1.x**' opera invocando una instancia de **/bin/bash** para ejecutar comandos de sistema. Se

identificó la ejecución de `'mkdir /var/www/html/d/'`, lo que asegura la existencia del directorio objetivo incluso si es eliminado. Finalmente, se capturó la llamada al sistema **write** inyectando el código HTML malicioso y confirmando que el binario posee el payload embebido, sobrescribiendo el archivo **'0001.html'** mediante la bandera **O_TRUNC**.

Análisis a nivel red

El malware **'cron1.x'** **NO** descarga la imagen de Internet. Simplemente escribe el texto HTML que contiene el enlace. Es el navegador de la víctima el que, al visitar la página infectada, realiza la petición al dominio siguiente:

<http://vignette4.wikia.nocookie.net/swfanon/images/2/27/CruentusLogo.png>.

Nota: La anterior URL maliciosa mostrada en este PDF no te lleva al sitio malicioso por seguridad.

El malware es autocontenido y no requiere conexión a internet del servidor para infectar el archivo (aunque sí para que la imagen se vea).

Lo anterior se confirma por el nulo tráfico capturado desde Wireshark relacionado a la ejecución del malware. La máquina utilizada para capturar actividad de red (**192.168.1.30**) fue usada como Gateway de la máquina usada para hacer el análisis del malware (**192.168.1.20**). Es decir, el análisis se hizo en un entorno controlado.

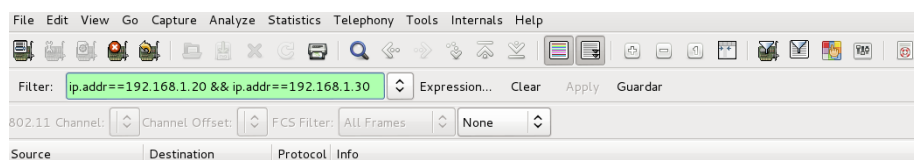


Imagen 28. Conversación completa entre máquinas

La imagen anterior confirma la nula interacción entre máquinas al momento de analizar el malware. Por lo que, en ningún momento se compromete la red.

Línea del tiempo

Cronología del Incidente de Seguridad (23 de noviembre de 2016)

Fecha y Hora	Categoría de Evento	Descripción Técnica de la Actividad	Evidencia / Artefacto
09:26:27	Acceso Inicial	Se registra un inicio de sesión exitoso para el usuario root tras un ataque de fuerza bruta por SSH.	auth.log / .bash_history
10:01:57	Gestión de Cuentas	Se crea el usuario apache para establecer una vía de acceso alternativa y mimetizada.	/etc/passwd / bash_history
10:06:22	Persistencia de Red	El atacante modifica el archivo /etc/ssh/sshd_config para habilitar un puerto de escucha adicional.	sshd_config / netstat
10:12:45	Despliegue de Malware	El binario cron1.x se traslada al directorio /usr/bin/ y se le otorgan permisos de ejecución.	ls -la / bash_history
10:13:33	Instalación de Persistencia	Se instala formalmente el archivo crontab para el usuario apache, automatizando la ejecución del malware.	/var/spool/cron/crontabs/
10:14:01 (Recurrente)	Ejecución de Carga	El servicio CRON invoca a cron1.x, el cual utiliza una shell de bash para sobreescribir el archivo 0001.html.	syslog / strace
--	Impacto en Integridad	Se confirma la presencia del mensaje de "The Imperial" y la imagen externa en el servidor web.	/var/www/html/d/ 0001.html

Recomendaciones para erradicación

Se necesita un plan de contención, seguridad en cuentas y accesos; y hardening de servicios expuestos.

Contención

- **Eliminación de Tareas Programadas (CRON):** Se debe eliminar de inmediato el archivo **crontab** del usuario **apache** y cualquier entrada sospechosa en el de **root** para detener la ejecución cíclica del malware.
- **Finalización de Procesos:** Es necesario identificar y terminar cualquier proceso activo relacionado con **/usr/bin/cron1.x** utilizando comandos como **pkill -9 cron1.x**.
- **Eliminación de todos los Artefactos Maliciosos:** Se debe eliminar el binario **/usr/bin/cron1.x** y borrar el directorio de “defacement” **/var/www/html/d/** junto con el archivo **0001.html**.

Seguridad en cuentas y accesos

- **Eliminación del Usuario de Respaldo:** Se debe proceder a la eliminación inmediata de la cuenta **apache** y sus directorios asociados para cerrar la vía de acceso mimetizada.
- **Rotación de Credenciales:** Es imperativo cambiar la contraseña del usuario **root** y de cualquier otra cuenta administrativa, ya que estas fueron comprometidas mediante fuerza bruta.
- **Auditoría de Llaves SSH:** Se deben revisar los archivos **authorized_keys** en busca de llaves públicas desconocidas que el atacante pudiera haber inyectado para mantener acceso sin contraseña.

Hardening de servicios expuestos

- **Restauración de Puertos:** Se debe eliminar la directiva de puerto adicional y asegurar que el servicio solo escuche en el puerto estándar o algún otro puerto monitoreado.
- **Deshabilitar Acceso a root desde SSH:** Cambiar la configuración a **PermitRootLogin no** para obligar el uso de usuarios con privilegios limitados y sudo.
- **Autenticación por Llaves:** Configurar **PasswordAuthentication no** para mitigar definitivamente ataques de fuerza bruta, permitiendo únicamente el acceso mediante llaves criptográficas.

Análisis elaborado por Aldo Santiago Alejandro.

Profesor: Ing. Víctor Enrique Arteaga Lona
